SIST Web Infrastructure System — AU-2 Audit Events Control Assessment Plan
Assess Task #1

1. Selected Control ID and Name (Copy from RMF4): AU-2: Audit Events

2. What is the objective of this control assessment?

   - The objective of this assessment is to evaluate whether the AU-2 Audit Events control is appropriately designed and implemented within the simulated, High-impact SIST AWS Web Infrastructure System. The assessment will examine whether required security events, such as user logins, system configuration changes, database access, and AWS API activity, are identified for auditing. It will also evaluate whether the proposed logging configuration supports the system's security and monitoring requirements.

3. What is the expected timeline of this assessment (i.e., how many hours, days, or weeks will the assessment take?)

The assessment will take approximately 32 hours (4 days).
- Documentation review – 8 hours
- Interviews – 6 hours
- Artifacts examination – 8 hours
- Control testing – 6 hours
- Reporting – 4 hours

4.Identify at least 3 artifacts you would hope to examine from the SIST Web Infrastructure System to assist with this assessment:

- SIST System Security Plan (SSP) and audit-event requirements
- AWS CloudTrail configuration and event-selection settings
- Amazon CloudWatch Logs configuration and log group settings
- Amazon S3 log storage configuration and retention policies
- AWS IAM policies and access management configurations

5. Using your answers and the rest of NIST 800-53A, now write an abbreviated assessment plan (3-4 paragraphs) for your control within the SIST Web Infrastructure System. The plan should include:
   The AU-2 Audit Events control assessment will focus on the simulated SIST AWS Web Infrastructure System, which supports the HR, GMAT, and FCIN applications. The assessment will involve the Information System Security Officer (ISSO), Cloud Infrastructure Administrator, and Security Operations

Team. Its purpose is to determine whether appropriate security events have been identified for auditing based on the system's High-impact categorization and security requirements.

The assessment will use three methods from NIST SP 800-53A: examine, interview, and test. The examine method will involve reviewing the SSP, documented audit-event requirements, AWS CloudTrail settings, CloudWatch Logs configurations, and related security documentation. The assessment will determine whether the proposed logging requirements identify relevant events and whether responsibility for selecting and updating those events is documented.

The interview method will involve speaking with the ISSO, Cloud Infrastructure Administrator, and Security Operations Team to understand how auditable events are selected, configured, and reviewed. The test method will involve planned controlled activities, such as user authentication attempts and IAM configuration changes, to evaluate whether selected events can be captured through the configured logging services. These tests would also provide supporting evidence for related audit controls.

The assessment findings will be documented in a report identifying any gaps between the documented audit-event requirements and the proposed AWS logging configuration. Any identified deficiencies would be recommended for remediation and, where appropriate, tracked through a Plan of Action and Milestones (POA&M). Because this is an academic simulation, these procedures represent a proposed assessment plan rather than completed control testing.

Assess Task #2

FedRAMP Plan of Action and Milestones (POA&M) Template

The FedRAMP Plan of Action and Milestones (POA&M) template was selected as a reference for documenting potential security control deficiencies within the simulated SIST AWS environment. The template provides a structured way to record identified weaknesses, risk severity, responsible personnel, planned corrective actions, and remediation timelines. Although the SIST assessment does not establish that the system requires FedRAMP authorization, the template offers a useful format for tracking security remediation activities in support of the NIST Risk Management Framework.

References

National Institute of Standards and Technology. (2018). Risk Management Framework for

Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy (SP 800-37 Rev. 2). https://doi.org/10.6028/NIST.SP.800-37r2

National Institute of Standards and Technology. (2020). Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. https://doi.org/10.6028/NIST.SP.800-53r5

National Institute of Standards and Technology. (2022). Assessing Security and Privacy Controls in Information Systems and Organizations (SP 800-53A Rev. 5). https://doi.org/10.6028/NIST.SP.800-53Ar5

National Institute of Standards and Technology. (2006). Guide for Developing Security Plans for Federal Information Systems (SP 800-18). https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-18r1.pdf

National Institute of Standards and Technology. (2004). Standards for Security Categorization of Federal Information and Information Systems (FIPS 199). https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.199.pdf

Amazon Web Services. (2024). AWS CloudTrail User Guide. https://docs.aws.amazon.com/cloudtrail/

Amazon Web Services. (2024). Amazon CloudWatch User Guide. https://docs.aws.amazon.com/cloudwatch/

Amazon Web Services. (2024). Amazon S3 User Guide. https://docs.aws.amazon.com/s3/

National Archives and Records Administration. (2024). Controlled Unclassified Information (CUI) Registry. https://www.archives.gov/cui/registry/category-list